

Technical Case Study — HealthyLife Clinic Data Classification & Handling Program

1. Background & Problem Statement

HealthyLife Clinic, a fictional mid-sized healthcare provider, processes large volumes of Protected Health Information (PHI) through its EHR system, billing platform, and clinical operations. The organization lacked a formalized data classification framework, resulting in inconsistent handling of sensitive data, unclear access boundaries, and increased exposure to privacy and compliance risks.

A structured Data Classification & Handling Program was required to reduce operational risk, support regulatory expectations, and standardize how staff interact with PHI and other sensitive data.

2. Project Objective

The objective of this project was to design and document a complete, audit-ready data governance framework that:

- Defines classification levels tailored to healthcare operations
- Establishes technical and administrative handling requirements
- Clarifies roles and responsibilities across clinical, IT, and compliance teams
- Provides staff with a simple, actionable awareness guide
- Demonstrates practical GRC and documentation skills in a healthcare context

3. Methodology

A structured, risk-based approach was used to build the program:

3.1 Data Discovery & Categorization

Identified common data types across clinical, operational, and administrative workflows, including PHI, billing data, HR data, and public-facing information.

3.2 Classification Model Development

Designed a four-tier classification model (Public, Internal, Confidential, Restricted/PHI) aligned with healthcare sensitivity levels and real-world risk impact.

3.3 Technical & Administrative Controls Mapping

Mapped each classification level to required controls, including:

- Encryption at rest and in transit
- MFA and least-privilege access
- Secure disposal procedures
- Monitoring and logging requirements

- **Restrictions on external sharing**

3.4 Governance Structure Definition

Defined responsibilities for Data Owners, Custodians, Users, Compliance Officers, Security Teams, and Clinical Staff.

3.5 Awareness & Training Material Creation

Developed a one-page visual guide summarizing classification levels and handling rules for non-technical staff.

4. Key Deliverables

4.1 Data Classification & Handling Policy (Word/PDF)

A comprehensive policy document outlining scope, objectives, classification levels, handling requirements, and governance roles.

4.2 Data Classification Matrix (Excel)

A structured matrix mapping each classification level to:

- **Description**
- **Examples**
- **Impact if compromised**
- **Required protection level**

4.3 Handling Requirements Framework

Lifecycle-based requirements covering storage, transmission, access, sharing, monitoring, and disposal.

4.4 Roles & Responsibilities Model

Clear accountability assignments for all stakeholders interacting with sensitive data.

4.5 One-Page Awareness Guide (PNG)

A simplified visual reference for staff, including a decision tree for classifying data.

5. Technical Skills Demonstrated

- **Governance, Risk & Compliance (GRC)**
- **Data classification & handling frameworks**
- **PHI protection and healthcare privacy concepts**
- **Policy writing and documentation**
- **Risk-based control design**
- **Access control and encryption requirements**

- **Communication and awareness development**
- **Professional GitHub documentation practices**

6. Outcome & Impact

The final program provides HealthyLife Clinic with a structured, repeatable, and audit-ready approach to managing sensitive healthcare data. It reduces compliance risk, improves operational consistency, and equips staff with clear guidance for handling PHI.

For portfolio and interview purposes, this project demonstrates the ability to design a complete governance framework from scratch—mirroring the work of a GRC analyst, compliance specialist, or cybersecurity governance professional.